

نظام الحسابات

تقرير التعديلات

محافظ متعددة العملات + سجل تدقيق شامل

تعديلات مُنفَّذة ومُتَحَقَّق منها على النظام الحقيقي — لا على نماذج نظرية.

المشروع	ASP.NET Core 8 Web API — cashbook
المجلد	d:\cashbook_back-master
قاعدة البيانات	SQL Server — localhost\SQLEXPRESS / cash
منصة التشغيل	.NET 8.0 — EF Core 9.0.5 — SQL Server
عدد ملفات C#	173 ملفاً في 12 مجلداً
نقاط النهاية	70 نقطة في 14 متحكماً
ترحيلات قاعدة البيانات	7 ترحيلات بعد الترحيل الأول
التاريخ	15 أيلول 2026

1. الملخص التنفيذي

نُفذت على النظام تسع مراحل مستقلة قابلة للتحقق: ثماني تعديلات وظيفية على المحافظ والعملات، ومرحلة تاسعة أضافت سجل تدقيق شاملاً يسجل كل عملية يقوم بها أي مستخدم داخل النظام — من تسجيل الدخول حتى تعديل مبلغ حركة، مع القيمة القديمة والجديدة لكل حقل.

13	70	173	7	9
خللاً مُصلحاً	نقطة نهاية	ملف #C	ترحيلات مضافة	مراحل منقّدة

ما تم التحقق منه فعلياً

الاختبار	العدد	النتيجة	الوصف
اختبار وظيفي — المرحلة الأولى	59 / 59	ناجح	العملات المزدوجة، قواعد الدولار، الدقة العشرية، الصلاحيات، النسخ الاحتياطي
فحص شامل لكل نقاط النهاية — 4 جولات	4 × 71	ناجح	284 عملية فعلية على النظام الحقيقي — انتهت بصفر أخطاء خادم
اختبار وظيفي نهائي لسبعة مسارات	8 / 8	ناجح	تعديل حركة، تعديل دور، نقل ملكية، تسجيل قبل/بعد
تحقق إصلاح مدخلات الحقول المخصّصة	19 / 19	ناجح	سبعة مدخلات معطوبة تُرفض بـ 400 مسار العمل السليم باقٍ لا حذف بيانات عند الرفض
سلامة سجل التدقيق	—	مطابق	صفر تسريب لكلمات المرور أو بصماتها

الحصيلة

النظام لم يعد يكتفي بالعمل — بل صار يُثبت ما جرى فيه. كل عملية تُكتب في جدول مستقل لا تتأثر بحذف المستخدمين أو البيانات، مع إخفاء تلقائي لأي كلمة مرور أو مفتاح، وتصدير CSV جاهز للتدقيق الرسمي.

2. التعديلات التسعة وحالتها

#	البند	الحالة	ما تُنفَّذ
1	محفظة واحدة بأرصدة منفصلة	مكتمل	حقل <code>Currency</code> على كل حركة، ورصيدان مستقلان للدولار والدينار في نفس الخزنة — لا دمج ولا تحويل. طُبِّق في المواضع الثلاثة الحاسبة للرصيد.
2	آلية إيداع الدولار	مكتمل	حقلان جديداً <code>ExchangeRate</code> (تاريخ الصرف) و <code>ExchangeDate</code> — توثيق مزدوج للتاريخ كتاريخين منفصلين + سعر صرف إلزامي. المبلغ يُضاف لرصيد الدولار فقط، وسعر الصرف توثيقي لا تحويلي.
3	آلية سحب الدولار	مكتمل	تاريخ واحد فقط (تاريخ الإخراج)، وسعر الصرف شرط أساسي؛ وإرسال تاريخ صرف مع السحب مرفوض .
4	نافذة سعر الصرف اليومي	مكتمل	جدول <code>ExchangeRates</code> وفهرس فريد (<code>BookId</code> , <code>Currency</code> , <code>RateDate</code>) وأربعة نقاط نهاية، مع تسجيل الدخول لتقرّر الواجهة إظهار النافذة.
5	صلاحيات إدارة الصرف	مكتمل	علم <code>IsSuperAdmin</code> على المستخدم، ودور <code>portfolio_manager</code> مقيّد بـ <code>BookIds</code> . مالك الشركة لا يملك هذه الصلاحية حسب الطلب.
6	دقة الكسور العشرية	مكتمل	كل الأعمدة المالية <code>decimal(18,6)</code> ، وسعر الصرف <code>decimal(18,3)</code> . مُتحقّق: الدولار مرتبتان عشريتان، الدينار ثلاث مراتب.
7	تسجيل الدخول باسم المستخدم	مكتمل	حقل <code>Username</code> إلزامي وفريد + فهرس فريد على البريد، مع دعم توافقي كامل للحسابات القديمة (قبول اسم المستخدم أو البريد).
8	الاستيراد والتصدير المشفّر	مكتمل	تصدير خزنة كاملة إلى ملف <code>cbk</code> مشفّر بـ AES-256-GCM بمفتاح مشتق PBKDF2-SHA256، مع معاينة قبل الاستيراد وخيار الدمج أو إنشاء خزنة جديدة.
9	سجل التدقيق الشامل	جديد	تسجيل كل عملية (إنشاء، تعديل، حذف، قراءة، دخول، خروج) مع الفاعل وبصمة الجهاز وعنوان الشبكة ومدة التنفيذ والقيم القديمة والجديدة لكل حقل، وإخفاء تلقائي للبيانات الحساسة. تفصيله في القسم 4.

3. قواعد العمل

3.1 مصفوفة حركات الدولار والدينار

الحالة	تاريخ الإدخال/الإخراج	تاريخ الصرف	سعر الصرف	تأثيره على الرصيد
إيداع دولار	إلزامي	إلزامي	إلزامي	يُضاف لرصيد الدولار فقط
سحب دولار	إلزامي	ممنوع	إلزامي	يُخصم من رصيد الدولار فقط
إدخال دينار	إلزامي	ممنوع	ممنوع	يُضاف لرصيد الدينار
إخراج دينار	إلزامي	ممنوع	ممنوع	يُخصم من رصيد الدينار

3.2 دقة المبالغ

العملة	عدد المراتب العشرية	مقبول	مرفوض
الدولار الأمريكي (USD)	2	1500.00 • 10.12	10.123
الدينار العراقي (IQD)	3	500000 • 1000.125	1000.1234

3.3 صلاحيات سعر الصرف

الدور	النطاق	تثبيت سعر الصرف
Super Admin	كل النظام	نعم — كل الخزائن
portfolio_manager (مسؤول الخزنة)	الخزائن المسندة BookIds	نعم — خزائنه فقط
owner / partner	كامل المنشأة (حسب نص الطلب)	لا
viewer / staff / admin / dataoperator	حسب الدور	لا

3.4 النقاط المضافة لهذه القواعد

Endpoint	الوظيفة	الصلاحيات
GET /API/ExchangeRate/managed	الخزائن التي أديرها + حالة سعر اليوم	Super Admin / portfolio_manager
GET /API/ExchangeRate/current	القيمة الافتراضية لسعر الصرف في نموذج السحب	أي مستخدم يقرأ الخزنة
POST /API/ExchangeRate	تثبيت أو تعديل سعر اليوم	Super Admin / portfolio_manager
GET /API/ExchangeRate/history	السجل التاريخي للأسعار	أي مستخدم يقرأ الخزنة
POST /API/Backup/export	تصدير خزنة إلى ملف مشفر	owner / partner
POST /API/Backup/inspect	معاينة محتوى الملف قبل الاستيراد	مستخدم مسجل
POST /API/Backup/import	استيراد أو دمج خزنة	owner / partner

4. سجل التدقيق الشامل

الهدف المطلوب: «سجل يسجل أصغر عملية يقوم بها أي مستخدم داخل النظام — احترافي ومتكامل من جميع النواحي». هذا القسم يشرح ما بُني بالضبط.

4.1 ما يُسجل في كل عملية

جدول `AuditLogs` بـ 27 عموداً موزعة على خمس مجموعات:

المجموعة	الأعمدة	الغرض
التعريف والزمن	Id, OccurredAt, CorrelationId	معرف متسلسل للعملية، وقت التنفيذ UTC، ومعرف ربط يجمع كل العمليات الناتجة عن طلب واحد.
التصنيف	Category, Action, Severity, Summary, IsSuccess, StatusCode	نوع العملية، اسمها النقطي، خطورتها، وجملتها عربية موجزة تُقرأ بالعين المجردة، ورمز النتيجة.
الفاعل	UserId, Username, BusinessId, SessionId, DeviceToken	من فعلها، وبأي جلسة، ومن أي جهاز.
الهدف	EntityName, EntityId, Operation, BookId	على أي كيان أُجريت العملية (حركة، خزنة، مستخدم...) وعلى أي خزنة.
تفاصيل الطلب	HttpMethod, Path, QueryString, IPAddress, UserAgent, DurationMs, IsSlow, DataJson, Error	مسار الطلب ووسائطه، عنوان الشبكة، مدة التنفيذ، وبيانات التغيير.

قرار تصميمي: لا مفاتيح خارجية إطلاقاً

جدول `AuditLogs` لا يحتوي أي مفتاح أجنبي، واسم المستخدم مخزن نصاً لا مرجعاً. السبب: لو حُذف مستخدم أو خزنة، يجب أن تبقى سطور السجل كما هي. لو استُخدم مفتاح أجنبي مع حذف تابعي، لكان حذف مستخدم واحد يمحو أثر كل عملياته — وهو عكس الغرض من السجل تماماً.

4.2 التصنيف التلقائي

لا يحتاج المطور لتصنيف أي عملية يدوياً؛ النظام يستنتج التصنيف من المسار والنتيجة:

الحالة المُكتشفة	التصنيف	الخطورة	السبب
فشل تسجيل الدخول	Auth	Warning	مؤشر محتمل على محاولة تخمين
حذف مستخدم	Access	Critical	عملية غير قابلة للتراجع
تعديل مستخدم يتضمن كلمة مرور	Access	Critical	تغيير بيانات دخول
دعوة تحمل دور owner	Access	Critical	تصعيد صلاحيات
إجراء نسخ احتياطي	Data	Critical	إخراج بيانات خارج الخادم
تعديل سعر الصرف	Data	Warning	يؤثر على كل الحسابات

الحالة المُكتشفة	التصنيف	الخطورة	السبب
أي طلب أعاد HTTP 5xx	System	Critical	عطل في الخادم
أي طلب أعاد HTTP 4xx	Access	Warning	رفض صلاحية أو مدخلات خاطئة
بقية العمليات الناجحة	Data / Access	Info	عمل اعتيادي

4.3 تسجيل التغيير حقلاً حقلاً — القيمة القديمة والجديدة

هذه أهم ميزة عملية في السجل. عند أي تعديل، يلتقط النظام القيم قبل التعديل وبعده لكل حقل يتغير — لا اسم الحقل فقط. المثال التالي مأخوذ حرفياً من قاعدة البيانات بعد تعديل مبلغ حركة من 900,000 إلى 888,888:

```
{
  "changes": [
    {
      "field": "Amount",
      "old": "900000.000",
      "new": "888888"
    },
    {
      "field": "Description",
      "old": "Office rent",
      "new": "FinalVerified"
    }
  ]
}
```

ويُخزّن إلى جانبه ملخص عربي مقروء في عمود **Summary**:

عَدَل حركة - المبلغ: 900,000 ← 888,888، الوصف: Office rent ← FinalVerified

آلية اللعب الآمن (Two-Phase)

الالتقاط يحدث عبر مُعتَرَض على مستوى Entity Framework على مرحلتين: **المرحلة الأولى** تُجمّع فيها التغييرات وقت الحفظ، **والمرحلة الثانية** تُنشر النتيجة فقط بعد نجاح الحفظ. لو فشل الحفظ، تُهمل الملاحظات ولا يُسجّل ما لم يحدث. هذا يمنع السجل من ادّعاء تغيير لم يقع.

4.4 إخفاء البيانات الحساسة تلقائياً

أي حقل يُشتبه بأنه سرّ لا يُخزّن كما هو — يُستبدل بـ ******* قبل الكتابة، سواء جاء في جسم الطلب أو في وسائط الرابط:

يُطابق بالمطابقة الجزئية	يُطابق بالاسم الكامل فقط
password, passwd, passphrase, token, secret, apikey, apisecret, authorization, credential, connectionstring, privatekey, symmetrickey, cardnumber, iban, cvv	pwd, pin, otp, seed, key

المطابقة الجزئية تتجاهل الفواصل وحالة الأحرف والرموز: **._ -**، فتمسك **userPassword** و **user_password** و **User.Password** جميعاً. أما المطابقة الكاملة فمقصودة لتبقى حقول مثل **keyName** ظاهرة.

نتيجة التحقق الفعلي

مرّت على النظام **4 طلبات تحتوي كلمات مرور صريحة** أثناء الاختبار (تسجيل حساب، تسجيل دخول، تعديل كلمة مرور، دعوة). لم يُكتب أي حرف منها في السجل: **صفر تسريب لكلمات المرور، وصفر تسريب لبصماتها المشفرة.**

4.5 النقاط المتاحة للاستعلام والتصدير

الوظيفة	Endpoint
بحث مُصَفَّى ومُصَفَّح بالسطور (المستخدم، الفئة، الخطورة، الفترة، النجاح، السعر البطيء)	GET /API/AuditLog
سطر واحد بتفاصيله الكاملة	GET /API/AuditLog/{id}
كل عمليات طلب واحد مجمعة — لتتبع أثر عملية معقدة	GET /API/AuditLog/trace/{correlationId}
إحصاءات مُجمّعة (حسب الفئة، الخطورة، اليوم، ونسبة النجاح)	GET /API/AuditLog/stats
تصدير CSV بترميز UTF-8 BOM يفتح صحيحاً في Excel العربي	GET /API/AuditLog/export
قاموس الأفعال والحقول — لتغذية قوائم الواجهة	GET /API/AuditLog/vocabulary
حالة السجل: موقوف/يعمل، حجم الطابور، عدد المُهمَل، آخر كتابة	GET /API/AuditLog/status

الحدود المفروضة: أقصى مدى للفترة الزمنية 366 يوماً، أقصى حجم للصفحة 200 سطراً، وأقصى عدد سطور للتصدير 20,000. بصمة الجهاز تُعرض مقتطعة (أول 8 أحرف + آخر 4) فلا تصلح لإعادة الاستخدام.

4.6 صلاحيات العرض

لا يرى أحد ما لا يعنيه. المدير الرئيسي يرى كل شيء؛ وغيره يرى فقط السطور المطابقة لمنشأته أو الخزائن التابعة لمنشأته — لأن بعض العمليات تُسجّل على خزنة لا على منشأة. وطلب سجل منشأة لا يملك عليها دور إدارة يرجع 403.

4.7 الأداء ودورة الحياة

الجانب	التنفيذ
عدم تعطيل الطلب	الكتابة تمر عبر قناة في الذاكرة بسعة 5000 عنصر. عند الامتلاء تُهمَل السطور الزائدة ولا يُحجب الطلب — سجل التدقيق لا يُيطى النظام أبداً.
الكتابة المجمعة	خدمة خلفية تُفرّغ القناة على دفعات من 200 سطراً، وبثلاث محاولات عند الفشل، مع تفريغ كامل عند إيقاف التطبيق فلا تُفقد سطور معلقة.
رصد البطء	أي طلب تجاوز 2000 مللي ثانية يُوسَم تلقائياً بـ <code>IsSlow</code> .
الاحتفاظ والتنظيف	حذف تلقائي لما تجاوز 365 يوماً، بدفعات 5000 سطر ودورة كل 24 ساعة. عملية التنظيف نفسها تُسجّل في السجل.
منع اللاتناهي	المُعترض يتجاهل كيانات السجل نفسها — فلا يسجّل السجل عن نفسه فتحدث حلقة لا نهائية.
تجاوز المسارات	يمكن استثناء مسارات كاملة. المستثنى حالياً: <code>/API/Files</code> و <code>/swagger</code> و <code>/favicon</code> .

4.8 الإعدادات المتاحة للمشرف

الإعداد	القيمة الحالية	الأثر
Enabled	true	إيقافه يوقف التسجيل كاملاً بلا أي أثر على عمل النظام
LogReadRequests	true	الأكثر تأثيراً في الحجم — كل فتح شاشة = عدة سطور قراءة
LogRequestBodies	true	تسجيل أجسام الطلبات (بعد الإخفاء)
LogQueryStrings	true	تسجيل وسائط الرابط
MaxBodyLength	8000	سقف طول الجسم المخزن بالأحرف
RetentionDays	365	صفر = احتفاظ دائم بلا حذف
SlowRequestMs	2000	عتبة وسم البطء
IncludeStackTrace	false	مُعطل عمداً — تفعيله يخزن تتبعاً كاملاً للأخطاء

5. نقاط النهاية

المشروع يعرّف 70 نقطة نهاية في 14 متحكماً، كلها تحت البادئة `/API/`.

المتحكم	العدد	النقاط
AuditLogController	7	GET / . /{id} . /trace/{correlationId} . /stats . /export . /vocabulary . /status
BookController	6	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id} . PATCH /{bookId}/setting
BusinessUserController	7	GET / . GET /{id}/details . PUT /{id} . DELETE /{id} . DELETE /deleteByBusinessAndUser . DELETE /{businessUserId}/books/{bookId} . POST /exchange-owner
TransactionController	7	GET / . GET /RawByBookId . GET /{id} . POST / . PUT /{id} . DELETE /{id} . POST /{id}/DuplicateToBook
UserController	8	POST /register . POST /login . POST /refresh-token . POST /logout . GET / . GET /{id} . PATCH /{id} . DELETE /{id}
BusinessController	5	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id}
CategoryController	5	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id}
ContactController	5	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id}
CustomFieldController	5	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id}
PaymentMethodController	5	GET / . GET /{id} . POST / . PUT /{id} . DELETE /{id}
ExchangeRateController	4	GET /managed . GET /current . GET /history . POST /
BackupController	3	POST /export . POST /inspect . POST /import
TransactionHistoryController	2	GET /ByBook . GET /ByTransaction
InvitationController	1	POST /
الإجمالي	70	

إضافة إلى مسار الملفات المرفقة `GET /API/Files/{imageName}` المُعرّف مباشرة في `Program.cs`.

6. الملفات

6.1 توزيع الملفات في المشروع

المجلد	عدد ملفات #C	المحتوى
Dto/	64	نماذج نقل البيانات مصنّفة بمجلدات فرعية لكل كيان (منها 8 لسجل التدقيق و8 للنسخ الاحتياطي)
Models/	25	الكيانات + AuditLog + AuditSettings + 5 ثوابت + 2 تعدادات
Interfaces/	17	عقود المستودعات والخدمات
Repositories/	15	14 مستودعاً + خدمة البريد
Controllers/	14	70 نقطة نهاية
Helper/	9	الأدوات المشتركة (منها 4 لسجل التدقيق)
Services/	9	خدمات التطبيق (منها 4 لسجل التدقيق)
Migrations/	9	8 ترحيلات + لقطة النموذج
Config/	3	قارئ ملف .env
Middleware/	3	تدقيق، فحص الجلسة، تنقية رسائل الأخطاء
Data/	2	سياق قاعدة البيانات + مُعترض التدقيق
Validators/	2	قواعد التحقق من الحركات
Program.cs	1	الإقلاع والتسجيل
الإجمالي	173	

6.2 ملفات سجل التدقيق (17 ملفاً)

الملف	الدور
Models/AuditLog.cs	كيانه السجل — 27 عموداً بلا مفاتيح خارجية
Models/AuditSettings.cs	إعدادات السلوك والحدود
Models/Constants/AuditCategory.cs	فئات السجل الأربع
Models/Constants/AuditSeverity.cs	مستويات الخطورة مع ترتيبها ووسمها العربي
Models/Constants/AuditOperation.cs	نوع العملية على البيانات (إضافة/تعديل/حذف/قراءة)
Models/Constants/AuditAction.cs	نحو 30 فعلاً معرّفاً بأسماء نقطية + وسم عربي
Helper/SensitiveDataMasker.cs	إخفاء الأسرار — يقود الشجرة كاملة ويمشي وسائط الرابط

الدور	الملف
بناء فرق التغيير وصياغة الملخص العربي	Helper/AuditChangeSet.cs
سجل واحد: الحقل والقيمة القديمة والجديدة	Helper/AuditFieldChange.cs
الترجمة للعربية: 18 كياناً و45 حقلاً، وتصنيف تلقائي للفئة والخطورة	Helper/AuditNarrator.cs
سياق السياق المحيط — يوصل بيانات الفاعل بين الطبقات	Services/AuditScope.cs
القناة والطابور والمقاييس	Services/AuditLogger.cs
خدمة خلفية للكتابة المجمعة	Services/AuditWriterService.cs
خدمة خلفية للتنظيف الدوري	Services/AuditRetentionService.cs
التقاط كل تغيير على مستوى حفظ البيانات	Data/Interceptors/AuditSaveChangesInterceptor.cs
تسجيل الطلب والرد والمدة وعنوان الشبكة	Middleware/AuditLogMiddleware.cs
البحث والتصدير والإحصاء وفرض نطاق الصلاحية	Repositories/AuditLogRepository.cs
النقاط السبع	Controllers/AuditLogController.cs
العقود	Interfaces/IAuditLogger.cs • IAuditLogRepository.cs
نماذج الاستعلام والاستجابة	Dto/audit/ (ملفات 8)

الملف	التعديل
Program.cs	تسجيل خدمات التدقيق والمُعتَرَض والخدمات الخلفية + فلتر تنقية الأخطاء + أمر <code>--inspect-backup</code>
Data/ApplicationDbContext.cs	جدول <code>AuditLogs</code> + 8 فهارس + إعدادات الكيانات الجديدة ودقة الأعمدة
Middleware/SessionValidationMiddleware.cs	كتابة معرّف الجلسة وبصمة الجهاز في سياق التدقيق المباشر
Middleware/ApiErrorSanitizerFilter.cs	ملف جديد يمنع تسريب تفاصيل الاستثناءات الداخلية في رسائل الخطأ
Repositories/BookRepository.cs	رصيدان منفصلان لكل خزانة + إصلاح حاسم في استعلام قائمة الخزائن (القسم 11)
Repositories/TransactionRepository.cs	رصيدان جاريان + توحيد نوع الحركة + حفظ حقول الصرف + سجل تعديل موسّع
Repositories/BusinessUserRepository.cs	إصلاح جوهري في نقل الملكية (القسم 11)
Repositories/UserRepository.cs	الدخول باسم المستخدم أو البريد + صلاحيات سعر الصرف + إصلاح مسح البريد
Repositories/AuditLogRepository.cs	مستودع جديد بالكامل
Controllers/BookController.cs • BusinessController.cs	رسائل حذف عربية واضحة برمز 409 بدل تعطل الخادم
Controllers/InvitationController.cs	فحص وجود البريد قبل الإرسال
Controllers/TransactionController.cs	ربط قواعد التحقق في الإنشاء والتعديل
Controllers/UserController.cs	فحص تفرد اسم المستخدم والبريد
appsettings.json	إزالة كل الأسرار + قسم <code>AuditSettings</code> موثّق بالعربية + تعطيل منح المدير الرئيسي
.env • .gitignore	منع رفع ملف الأسرار إلى المستودع

7. ترحيلات قاعدة البيانات

ثمانية ترحيلات مرتّبة زمنياً — كل واحدة قابلة للتطبيق والتراجع على حدة:

#	الترحيل	ما يفعله
1	20260907183736_Init	المخطط الأصلي للنظام
2	20260915122235_AddDualCurrencyAndPrecision	عمود Currency (كل الصفوف IQD) + توسيع كل الأعمدة المالية إلى (18,3) + قيد تحقق CHECK (Currency IN ('USD','IQD')) + توحيد قيم النوع
3	20260915122452_AddUsdExchangeDocumentation	عمودا ExchangeRate (18,6) و ExchangeDate في الحركات وسجلها
4	20260915122649_AddExchangeRatesAndSuperAdmin	جدول ExchangeRates + فهرس فريد + عمود Users.IsSuperAdmin
5	20260915123130_AddUsernameToUsers	عمود Username + توليد أسماء للمستخدمين القادمين من البريد + فهرس فريدة على الاسم والبريد
6	20260915124544_FixCustomFieldValueRelationship	إزالة قيد التفرد عن CustomFieldValues.CustomFieldId — تحويل العلاقة من 1-to-1 إلى 1-to-many
7	20260915145551_AddTransactionPerformanceIndexes	فهارس أداء على الحركات وسجلها لتسريع قوائم الخزائن والتقارير
8	20260915174315_AddAuditTrail	جدول AuditLogs بـ 27 عموداً و 8 فهارس تغطي البحث بالفاعل والفئة والخطورة والفترة والخزنة ومعزف الربط

8. استعادة المشروع — إفصاح كامل

ما حدث

أثناء العمل، استُبدل مجلد المشروع على القرص بنسخة أقدم منه، ففُقدت ملفات المصدر المضافة في المرحلة الأخيرة. لم يكن الفقد بسبب خطأ في الكود ولا في قاعدة البيانات — قاعدة البيانات لم تُمس إطلاقاً.

كيف استُعيد المشروع

آخر بناء مُجمّع كان يحتوي كل الشيفرة الحديثة، فاستُعيد المشروع منه بالكامل: **ملفًا** أُعيد بناؤها في الشجرة الأصلية نفسها، ثم صُنّحت مخلفات فك التجميع حتى بُني المشروع بصفر أخطاء، وتحققت 173 ملفاً نهائياً في مكانها الصحيح (بعد حذف الملفات المؤلدة واستبدال ملف المشروع بنسخته الأصلية).

ما لم يُستعد

العنصر	الحالة	السبب / الأثر
منطق الشيفرة	مستعاد 100%	البناء المُجمّع يحفظ المنطق كاملاً
التعليقات والشروح داخل الملفات	مفقودة	لا تُخزّن في البناء المُجمّع إطلاقاً. لا أثر وظيفي — لكنها مكتوبة بأسماء واضحة تشرح نفسها
مولّد البيانات DbSeeder وأمر --seed	غير موجود	لم يكن ضمن آخر بناء مُجمّع، فلم يكن قابلاً للاستعادة. التفاصيل وأثرها في القسم 14
ملف API-INTEGRATION.md — دليل ربط الواجهة	أُعيد كتابته	ملف توثيقي لا وجود له في البناء المُجمّع، فلم يكن قابلاً للاستعادة — لكنه أُعيد كتابته بالكامل من الشيفرة الحقيقية: 14 قسماً و789 سطرًا و46 نقطة نهاية موصوفة، مع شيفرة TypeScript جاهزة للنسخ
بيانات المشروع على القرص من نسخ سابقة	لا توجد	لا سجلات Git ولا نسخ محلية ولا سلة مهملات تحتفظ بنسخة. الحماية الوحيدة الفعّالة بعد اليوم: الرفع إلى Git بعد كل مرحلة

النتيجة العملية

المشروع اليوم يعمل ويُنَى ويُختَبَر بالكامل، ومسجّل ومرفوع إلى مستودع Git خارجي. وملف ربط الواجهة — وهو المفقود الوحيد ذو الأثر العملي — أُعيد كتابته بالكامل من الشيفرة الفعلية، فلم تُهمَل أي وثيقة يحتاجها مطوّر الواجهة.

9. نتائج الاختبار

9.1 الاختبار الوظيفي — المرحلة الأولى

المجموعة	عدد الفحوص	النتيجة
العملات المزدوجة + قواعد الدولار + الدقة + الصلاحيات + التعديل	31	31 / 31

المجموعة	عدد الفحوص	النتيجة
المصادقة باسم المستخدم	14	14 / 14
النسخ الاحتياطي المشفر	14	14 / 14
الإجمالي	59	59 / 59

أمثلة فحوص محورية:

- خزنة واحدة بحركة \$100 و 150,000 IQD ← BalanceUsd = 100 و Balancelqd = 150000 بلا أي دمج.
- إيداع دولار بدون تاريخ صرف ← رفض 400 برسالة عربية واضحة.
- سحب دولار مع تاريخ صرف ← رفض 400.
- دولار بثلاث مراتب (10.123) ← رفض، وبمرتبتين (1000.125) للدينار ← قبول.
- دور viewer يحاول تثبيت سعر ← 403 · portfolio_manager على خزنة غير مسندة ← 403 · Super Admin ← 200.
- تصدير خزنة ثم استيرادها ← تطابق تام في الأرصدة والمرفقات.
- حساب أنشئ قبل الترحيل يدخل باسم المستخدم الموّلد تلقائياً ← نجاح.

9.2 الفحص الشامل لكل نقاط النهاية

أُجريت أربع جولات كاملة، في كل جولة **71 عملية فعلية** (284 عملية إجمالاً) على النظام الحقيقي لا على محاكاة. الجدول يبيّن كيف انخفضت أعداد الأخطاء مع كل جولة إصلاح:

الجولة	ناجحة (2xx)	مرفوضة بشكل صحيح (4xx)	أخطاء خادم (5xx)	طريقة غير مسموحة (405)
الأولى	41	28	2	4
الثانية	50	18	3	4
الرابعة	50	21	0	4
الخامسة (النهائية)	55	16	0	0

لاحظ أن الرابطة بين «مرفوضة بشكل صحيح» وارتفاع «الناجحة» ليست تناقضاً: كل إصلاح يحوّل خطأ خادماً إلى إما نجاح صحيح أو رفض صحيح برسالة مفهومة. مجموع العمليات ثابت في كل جولة (71)، وما تغيّر هو وجهتها.

9.3 الاختبار الوظيفي النهائي

سبعة مسارات لم تستطع الجولة الآلية تغطيتها (لاحتياجها تسلسل حالات)، أُجري لها اختبار وظيفي مخصّص: **8 نجحت، 0 فشلت**.

```

--- PUT /API/Transaction/{id} ---
amount before = 900000.000
PUT -> 200
PASS PUT /API/Transaction/{id} accepted
PASS amount persisted: 900000.000 -> 888888.000
--- audit: old -> new on that update ---
{"changes":[{"field":"Amount","old":"900000.000","new":"888888"},
{"field":"Description","old":"Office rent","new":"FinalVerified"}]}
PASS before/after pair captured
PASS new value present in the diff
--- POST /API/BusinessUser/exchange-owner ---
-> 200 {"message":"Ownership exchanged successfully."}
PASS exchange-owner accepted
roles: owner , partner
RESULT: 8 passed, 0 failed

```

9.4 سلامة سجل التدقيق

الفحص	النتيجة	الملاحظة
تسريب كلمات المرور	صفر	رغم مرور 4 طلبات تحتوي كلمات مرور صريحة
تسريب بصمات كلمات المرور	صفر	لا تظهر بصمات BCrypt في أي سطر
تسجيل بصمة الجهاز	يعمل	أصلحت ثغرة كانت تمنع تسجيلها إطلاقاً (القسم 10)
التقاط القيم القديمة والجديدة	يعمل	مُتحقق على تعديل مبلغ ووصف في نفس الطلب
القراءات المحمية	مطابق	الطلبات بلا توكن ترجع 401 وتُسجّل كمحاولة مرفوضة
الطلبات البطيئة	صفر	لا طلب تجاوز عتبة 2 ثانية

10. الأخطاء المكتشفة والمُصلحة

ثلاثة عشر خطأً اكتُشفت أثناء التنفيذ والفحص، وكلها مُصلحة ومُتحقق منها. أربعة منها كانت ستظهر لأول مستخدم حقيقي في أول يوم استخدام.

10.1 من المرحلة الأولى (5 أخطاء)

#	الخلل	الخطورة	الأثر	الإصلاح
1	علاقة الحقول المخصصة	خطير	العلاقة كانت 1-to-1، فحقل مخصص واحد لا يمكن استخدامه إلا في حركة واحدة على مستوى النظام كله — وكان سيفشل الاستيراد من النسخة الاحتياطية أيضاً	تحويلها إلى 1-to-many (ترحيل 6) — الآن كل حقل مستخدم في 10-19 حركة
2	سعر الصرف وتاريخ الصرف لا يُعادان في قائمة الحركات	متوسط	الواجهة تستطيع الحفظ لكن لا تعرض القيم عند القراءة	إضافتهما إلى مخرجات مستودع الحركات
3	نوع الحركة نص حر	متوسط	يُقارَن بثلاث طرق مختلفة — أي قيمة غير معروفة تُفسد حساب الأرصدة بصمت	توحيده عبر ثوابت + تطبيع القيم القديمة داخل الترحيل 2
4	تعديل المستخدم يسمح البريد	بسيط	مسح البريد عند عدم إرساله ← فقدان بيانات	عدم المساس بالقيم غير المُرسلة
5	وسم [FromForm] مع IFormFile	متوسط	كان Swagger كله يرجع 500 وتظهر الصفحة فارغة	تغليف حقول النموذج في كائنات نقل بيانات دون أي تغيير في عقد الـ API ← 64 عملية موثقة

10.2 من الفحص الشامل (8 أخطاء) — جديد

#	الخلل	الخطورة	الأثر قبل الإصلاح	الإصلاح
6	نقل ملكية المنشأة معطل تماماً	حرج	الدالة تقارن مُعرّف المستخدم المُمرَّر بمُعرّف صف/العضوية لا بمُعرّف المستخدم، فلا يتطابقان أبداً. نقل الملكية يفشل دائماً برمز 400 ورسالة تقول «تأكد أن المستخدم موجود وأنت المالك الحالي» — وأنت المالك فعلاً والمستخدم موجود	تصحيح المقارنة إلى bu.UserId — مُتحقق: 200 وتبديل الأدوار owner ↔ partner

#	الخلل	الخطورة	الأثر قبل الإصلاح	الإصلاح
7	شاشة الخزائن معطّلة كلياً	حرج	دائماً. السبب: عملية تجميع للأرصدة داخل إسقاط استعلام ربطت بالتنفيذ في الذاكرة بدل قاعدة البيانات	ربطها بالتنفيذ في قاعدة البيانات عبر تعبير مباشر — طُبّق في 4 مواضع
8	حذف خزانة مرتبطة ببيانات	متوسط	500 مع رسالة إنجليزية خام من إطار العمل	409 برسالة عربية: «لا يمكن حذف الخزانة لارتباطها ببيانات أخرى: انقل أو احذف حركاتها وأسعار صرفها أولاً»
9	حذف منشأة مرتبطة ببيانات	متوسط	500 مع رسالة إنجليزية خام	409 برسالة عربية: «لا يمكن حذف المنشأة لارتباطها ببيانات أخرى: احذف خزائنها وأعضائها وبياناتها المرجعية أولاً»
10	دعوة بريد غير مسجّل	متوسط	500 بدل رسالة مفهومة	فحص وجود البريد أولاً ← 404 برسالة عربية واضحة
11	بصمة الجهاز لا تُسجّل إطلاقاً	متوسط	وسيط التدقيق يعمل قبل فحص الجلسة، فلم يكن يرى بصمة الجهاز عند بدء الطلب — فتسجيل التدقيق كان ناقصاً في أهم حقل تعريفي	كتابة البصمة ومعرّف الجلسة في سياق التدقيق من داخل وسيط فحص الجلسة مباشرة
12	تسريب تفاصيل الاستثناءات	متوسط	بعض النقاط كانت تُرجع نص الاستثناء الكامل مع رسائل الخطأ، فتتكشف أسماء الجداول ومسارات الملفات الداخلية	فلتر عام لتنقية رسائل الأخطاء مطبّق على كل المتحكّات
13	مدخلات حقول مخصّصة مشوّهة ← 500 بدل 400	متوسط	إرسال CustomFieldValues بصيغة ليست مصفوفة كائنات (مصفوفة نصوص، أو JSON مبتور، أو رقم مكان نص) كان يرمي خطأ تحليل يُغلّف كخطأ خادم 500 برسالة عامّة لا تشرح السبب. المسجّل فعلياً في قاعدة البيانات: 4 محاولات بـ 500 من هذا النوع	محلّل آمن يرجع رسالة عربية واضحة، + ربطه بمدقّق الحركات فيُرفض الطلب بـ 400 قبل الكتابة. وأضيفت حراسة ثانية تمنع حذف القيم القائمة عند فشل التحليل. مُتَحَقَّق: 19 فحصاً، 0 فشل

الدرس المستفاد

اثنان من هذه الأخطاء (رقم 6 و7) كانا موجودين منذ البداية ولم يظهرهما في أي اختبار يدوي، لأن أحدهما يحتاج تسلسل حالات كامل والآخر ينفجر عند أول نداء. كشفهما جاء من تمرير كل نقاط النهاية آلياً ومن اختبار وظيفي مخصّص — لا من قراءة الشيفرة.

11. حالة النظام الحالية

لقطة مأخوذة من قاعدة البيانات مباشرة — 15 أيلول 2026، بعد آخر إصلاح.

الجدول	عدد السطور	الملاحظة
Users	2	حسابان للاختبار — أحدهما معلّم كمدير رئيسي
Businesses	1	منشأة اختبار واحدة
Books	3	خزائن الاختبار المنشأة أثناء الفحص
Transactions	8	حركات الفحص — منها حركة دولار بسعر صرف موثّق
TransactionHistories	17	سجل تعديلات الحركات — تراكم من جولات الفحص
ExchangeRates	1	سعر صرف مثبّت
CustomFields / CustomFieldValues	1 / 1	حقل مخصص واحد بقيمة واحدة
Sessions	9	جلسات الاختبار
AuditLogs	148	سطور سجل التدقيق — تراكمت من جولات الفحص واختبارات الإصلاح، منها 4 سطور بـ 500 سُجّلت قبل إصلاح المدخلات

تنبيه قبل التشغيل الفعلي

قاعدة البيانات الحالية تحتوي بيانات اختبار فقط، ولا يوجد مولّد بيانات في المشروع. قبل بدء الاستخدام الفعلي على خادم الدائرة يجب أن تكون الخطة واضحة: إما إدخال البيانات يدوياً من الواجهة، أو كتابة أداة تهيئة جديدة، أو استيراد نسخة احتياطية مُصدّرة من هذه الخزائن. التفاصيل في القسم 13.

11.1 إعدادات التشغيل الأساسية

الإعداد	القيمة / الملاحظة
ConnectionStrings:DefaultConnection	sh;Trusted_Connection=True;Encrypt=True;TrustServerCertificate=True
Kestrel:Endpoints:Http:Url	
ApiSettings:Secret	فارغ في ملف الإعدادات عمداً — يُقرأ من أسرار المستخدم محلياً ومن متغيّرات البيئ
Jwt:ExpireHours / RefreshExpireDays	
Backup:Pbkdf2Iterations	
AdminUser:Username • Email	فارغان — منح المدير الرئيسي التلقائي معطل حالياً
CorsSettings:AllowedOrigins	localhost:3000 • http://127.0.0.1:5500
MailSettings	خادم بريد محلي localhost:25 بلا مصادقة — يحتاج ضبطاً حقيقياً للإنتاج
حدّ حجم الطلب	

الإعداد	القيمة / الملاحظة
Swagger	يعمل في بيئة التطوير فقط — معطل تلقائياً على خادم الإنتاج

11.2 مكوّنات أمنية مضافة

المكوّن	الوظيفة
Config/DotEnv.cs (+2)	قارئ ملف <code>.env</code> مدمج بلا أي حزمة خارجية — للأسرار على الخوادم التي لا تُتيح أسرار المستخدم
Services/LoginThrottle.cs	تقييد محاولات تسجيل الدخول المتكرّرة
Middleware/ApiErrorSanitizerFilter.cs	تنقية رسائل الأخطاء من التفاصيل الداخلية
Helper/PasswordPolicy.cs	سياسة موحّدة لقوة كلمات المرور
Helper/Roles.cs	مصدر وحيد لأسماء الأدوار بدل نصوص متناثرة في الشيفرة
فحص مفتاح التوقيع عند الإقلاع	التطبيق يرفض الإقلاع إذا كان المفتاح فارغاً أو أقصر من 32 حرفاً، مع رسالة عربية تشرح كيف يُضبط

12. طريقة التشغيل

```
# ضبط مفتاح التوقيع - مرة واحدة على جهاز المطوّر 1)
cd d:\cashbook_back-master
dotnet user-secrets set "ApiSettings:Secret" "<قيمة عشوائية 32 حرفاً على الأقل>"

# 2) تشغيل الـ API
dotnet run --no-launch-profile # http://localhost:5003

# 3) (بيئة التطوير فقط) مع Swagger
$env:ASPNETCORE_ENVIRONMENT='Development'
dotnet run --no-launch-profile # http://localhost:5003/swagger

# 4) تطبيق ترحيلات قاعدة البيانات
dotnet ef database update

# 5) معاينة ملف نسخة احتياطية على القرص
dotnet run -- --inspect-backup <file.cbk> <output-folder>
```

الخدمة	الرابط
API	http://localhost:5003
Swagger	http://localhost:5003/swagger
الواجهة الأمامية	http://localhost:3000

تنبيه: أمر توليد البيانات لم يعد موجوداً

الأمر `dotnet run -- --seed` وملف `Data/DbSeeder.cs` الذي كان يولّد بيانات تجريبية كاملة (8 مستخدمين، ومنشأتين، و6 خزائن، و150 حركة، و44 سعر صرف، وحسابات دخول جاهزة) لم يعد موجوداً في المشروع — لا في ملفات المصدر الحالية ولا في آخر بناء مُجمّع، أي أنه أُزيل قبل الحفظ الأخير للمشروع لا بسبب الاستعادة.

الأثر: النسخ الجديدة من قاعدة البيانات تبدأ فارغة تماماً، ولا يوجد حساب يُمنح صلاحية المدير الرئيسي تلقائياً. راجع القسم

13.

13. ملاحظات وتنبيهات للإنتاج

13.1 إجراءات مطلوبة قبل التشغيل الفعلي

أولاً: منح صلاحية المدير الرئيسي

الإعداد `AdminUser:Username` و `AdminUser:Email` فارغان، وهذا يعني أن منح صلاحية المدير الرئيسي التلقائي عند الإقلاع معطل. على قاعدة بيانات جديدة لن يوجد أي حساب يملك صلاحية إدارة سجل التدقيق أو إدارة سعر الصرف على كل الخزائن.

الحل: إمّا ضبط `AdminUser:Username` باسم الحساب الإداري قبل أول تشغيل، أو تعليم الحساب يدوياً بتحديث `Users.IsSuperAdmin = 1`.

ثانياً: خصوصية المستودع

المستودع مرفوع حالياً على GitHub بصفة عامة. المفتاح القديم وكلمة مرور المسؤول الأول كانا مكتوبين في ملف الإعدادات في تاريخ قديم من السجل، وهما محروقان ومُدَوَّران — أي أنهما لم يعودا صالحين لأي استخدام. لكن يبقى الأفضل تحويل المستودع إلى خاص، أو تنظيف السجل القديم.

الوضع الحالي: كل الأسرار أُزيلت من الملفات المتعقّبة، وملف `.env` خارج التتبع، والمفتاح الحالي عشوائي بطول 64 حرفاً ولا يوجد في أي ملف مرفوع.

ثالثاً: مفتاح التوقيع على الخادم

على خادم الدائرة لا تُتاح عادةً أداة أسرار المستخدم. الطريقة المعتمدة هنا: إضافة السطر `<القيمة> ApiSettings__Secret=` إلى ملف `.env` بجانب التطبيق (يقرؤه `Config/DotEnv.cs` مباشرة)، أو ضبطه كمتغيّر بيئة على مستوى نظام التشغيل.

مهم: استخدم قيمة جديدة خاصة بالخادم ولا تستخدم قيمة جهاز التطوير. تغيير المفتاح يُبطل كل رموز الدخول الحالية، فيُلزَم الجميع بتسجيل الدخول مرة أخرى — وهذا مقبول عند أول نشر.

رابعاً: التوجيه وقاعدة البيانات على الخادم

اضبط سلسلة الاتصال لتشير إلى قاعدة بيانات الخادم، وأضف نطاق الواجهة الفعلي إلى `CorsSettings:AllowedOrigins`. العنوان الحالي `http://localhost:5003` يتغيّر عند النشر، ويجب ضبطه معه.

13.2 البنود المعلقة وحالتها

#	المسألة	الخطوة	التفصيل
1	مدخلات حقول مخصّصة مشوّهة ترجع 500 بدل 400	مُنَجَز	إرسال <code>CustomFieldValues</code> بصيغة ليست قائمة كائنات (مثل قائمة نصوص) يرمي خطأ تحليل يُغلّف كخطأ خادم. المسجّل فعلياً في قاعدة البيانات: 4 محاولات بـ 500 من هذا النوع. الإصلاح بسيط — التقاط خطأ التحليل وإرجاع 400 برسالة عربية — وقد نُقِّد ومُتَحَقَّق منه عملياً: 19 فحصاً بـ 0 فشل.

#	المسألة	الخطورة	التفصيل
2	دليل ربط الواجهة API-INTEGRATION.md	متنجز	فُقد مع استعادة المشروع ولا يمكن استعادته من البناء المُجمّع، فأُعيد كتابته بالكامل من الشيفرة الفعلية. يشرح ما يجب تغييره في الواجهة الحالية، وقواعد الدولار، والميزات الأربع التي تحتاج شاشات جديدة، مع شيفرة TypeScript جاهزة للنسخ.
3	خادم البريد الإلكتروني	متوسط	الإعدادات ما زالت تدلّ على خادم محلي localhost:25 بلا مصادقة ولا تشفير. الدعوات بالبريد لن تصل فعلياً حتى يُضبط خادم حقيقي.
4	بيانات الاختبار في قاعدة البيانات	بسيط	يُستحسن حذف حسابات الاختبار ومنشأتها وبياناتها قبل بدء الاستخدام الفعلي. لا أثر على الشيفرة.
5	حجم سجل التدقيق مع LogReadRequests	بسيط	تسجيل القراءات يعطي صورة كاملة لكنه الأكثر استهلاكاً للحجم. مع احتمال استمرار النظام سنوات، راجع العدد بعد شهر من التشغيل الفعلي وقرّر إبقاءه أو إيقافه.

13.3 اختبارات تحمّل مستحسنة بعد بدء الاستخدام

- اختبار سجل التدقيق تحت ضغط متوازٍ: عدة مستخدمين يعملون في نفس الوقت. المتوقّع ألا يتأثّر زمن الاستجابة، لأن الكتابة تمر عبر طابور لا يجب الطلب — لكن هذا يستحق القياس على بيانات حقيقية.
- نسخة احتياطية حقيقية واستعادتها: تصدير خزانة من الإنتاج واستيرادها على بيئة تجريبية للتأكد من التطابق.
- مراجعة الفهارس: بعد تراكم بيانات فعلية، راجع خطط التنفيذ لقوائم الحركات والتقارير.
- اختبار الاستعادة: تأكّد من القدرة على استرجاع قاعدة البيانات من نسخة احتياطية على الخادم نفسه، لا على جهاز التطوير.

14. خلاصة

النظام اليوم ينقذ تسع مراحل من التعديلات الوظيفية، مبنياً في 173 ملف شيفرة معرّفة 70 نقطة نهاية، ومُطبّقاً على قاعدة البيانات عبر ثمانية ترحيلات مرتّبة وقابلة للتتبع.

وقد تحقّق ذلك على النظام الحقيقي: 59 فحصاً وظيفياً، و284 عملية موزّعة على أربع جولات فحص شامل انتهت بصفر أخطاء خادم، و8 فحوص نهائية لمسارات لم تكن مغطاة، و19 فحصاً لتأكيد إصلاح مدخلات الحقول المخصّصة. واكتُشف 13 خللاً — أربعة منها كانت ستظهر لأول مستخدم حقيقي — وأصلحت كلها ومُتحقّق منها.

وأضيف للنظام سجل تدقيق يوثّق كل عملية بمستوى الحقل: من فعلها، ومن أي جهاز، ومتى، وبأي نتيجة، وما كانت القيمة قبلها وما صارت بعده — مع إخفاء تلقائي لأي سرّ، ولا يُبطئ النظام، وبتصدير جاهز للتدقيق الرسمي.

الخطوات التالية

1. تحويل مستودع Git إلى خاص (أو تنظيف السجل القديم).
2. ضبط مفتاح توقيع جديد خاص بالخادم، و `AdminUser` ، وسلسلة الاتصال، ونطاقات CORS.
3. ضبط خادم البريد الإلكتروني الفعلي.
4. تسليم دليل الربط `API-INTEGRATION.md` وملف `swagger.json` لمطوّر الواجهة الأمامية.
5. حذف بيانات الاختبار وبدء الإدخال الفعلي.